Diplomatura en Ciberseguridad

Título:
Trabajo Práctico – Módulo 3: Defensa en Profundidad

Estudiante:
Lucas Caminos

Profesor:
Juan Carlos Casale

Fecha:
8 de agosto de 2025

Caso 1 – Estudio financiero / Ransomware

Contexto y diagnóstico

El estudio cuenta con 20 estaciones de trabajo, tres sistemas de gestión y un servidor Windows con dominio para control de usuarios y recursos compartidos. Durante el fin de semana, un actor malicioso accedió al servidor, desplegó un archivo ejecutable en segundo plano y propagó un ransomware por toda la red. El lunes, ningún usuario pudo acceder a sus archivos ni a determinados sistemas, deteniendo la operación por completo.

En la evaluación inicial se detectaron vulnerabilidades críticas:

- **Credenciales por defecto** en el servidor ("admin / 123admin"), sin políticas de expiración ni autenticación multifactor.
- **Backup conectado físicamente** al servidor mediante USB, borrado con *low data wipe*, sin retención externa.
- **Sistemas obsoletos en D.O.S.**, con vulnerabilidades conocidas y sin parches disponibles, integrados en la misma red de producción.

Abordaje y acciones iniciales

La primera comunicación con la gerencia se enfocó en escuchar la descripción del incidente, transmitir calma y explicar el plan de trabajo. Antes de iniciar, se acordaron alcance y costos estimados, priorizando la transparencia y el registro de las tareas.

Se procedió a:

1. **Aislar** el servidor y los equipos afectados de la red para evitar cifrados adicionales.
2. **Buscar respaldos externos** o medios no conectados para evaluar opciones de recuperación.
3. **Preservar evidencia digital** mediante imágenes bit a bit del servidor y equipos clave, respetando la cadena de custodia para un análisis forense posterior.

Análisis técnico y medidas propuestas

Este incidente expone la ausencia de una estrategia de **Defensa en Profundidad** y políticas **Zero Trust**. La falta de segmentación permitió la propagación lateral sin restricción; las credenciales débiles facilitaron el acceso inicial; la inexistencia de backups offline eliminó toda posibilidad inmediata de restauración; y los sistemas legados añadieron superficie de ataque.

Plan de remediación y fortalecimiento:

- **Identidades y accesos:** eliminación de credenciales por defecto, políticas de contraseñas robustas, autenticación multifactor para cuentas privilegiadas.
- **Infraestructura de red:** segmentación en VLAN para separar servidores, estaciones de trabajo y sistemas legados; implementación de NAC para validar dispositivos.
- **Copias de seguridad:** política 3-2-1 (tres copias, dos soportes distintos, una offline); cifrado y verificación de integridad mediante hash; simulacros de restauración periódicos.
- **Protección de endpoints:** EDR con respuesta automatizada, antivirus corporativo actualizado, control de dispositivos USB.
- **Sistemas obsoletos:** aislamiento físico o virtualización en entornos controlados, sin acceso directo a la red productiva.
- **Capacitación interna:** sesiones periódicas sobre phishing, ransomware y manipulación de ingeniería social, usando materiales claros como las guías de Europol.

Conclusión

Este ataque no solo fue posible por fallos técnicos, sino por la ausencia de una cultura de seguridad preventiva. Aplicar controles en capas, segmentar entornos y reforzar credenciales habría reducido drásticamente el riesgo. Con un plan de respuesta documentado y respaldos desconectados, la organización habría podido reanudar operaciones en horas en lugar de días o semanas.

Caso 2 – Barrio cerrado / Videograbación

Contexto y diagnóstico

El barrio cerrado cuenta con una casilla de guardia y un sistema de videovigilancia cableado que transmite a una central con DVR (Digital Video Recorder). La administración detectó un posible incumplimiento grave: el vigilador nocturno fue grabado durmiendo durante su turno. Se solicita obtener y resguardar las grabaciones correspondientes a fechas y horarios específicos, junto con un video capturado por smartphone, para fundamentar una desvinculación laboral con posible derivación judicial.

En este contexto, cualquier manipulación indebida del material podría invalidar la prueba. Por lo tanto, el objetivo principal es garantizar la **integridad**, **confiabilidad** y **trazabilidad** del proceso de extracción y custodia.

Abordaje y acciones iniciales

En la reunión inicial con el cliente, se escucha con detalle la descripción del incidente y se clarifican las necesidades legales. Se transmite tranquilidad asegurando que existen procedimientos para preservar las pruebas, y se acuerda por escrito el alcance del trabajo, incluyendo tiempos, recursos necesarios y costos, para evitar cualquier malentendido.

Con el marco acordado, se planifica la intervención siguiendo principios de informática forense: minimizar manipulación de la evidencia original y documentar cada paso.

Análisis técnico y pasos de preservación

Para que las grabaciones sean aceptadas como prueba judicial, se debe cumplir con la cadena de custodia y estándares forenses:

1. **Asegurar el dispositivo**: desconectar el DVR del acceso a usuarios no autorizados y bloquear cualquier grabación automática que pueda sobrescribir el material.
2. **Registro inicial**: documentar en acta la marca, modelo, número de serie y estado físico del DVR y disco rígido, junto con la fecha y hora del sistema.
3. **Extracción controlada**: realizar una copia bit a bit (imagen forense) del disco del DVR usando herramientas certificadas, sin modificar datos.
4. **Verificación de integridad**: calcular y registrar el hash criptográfico (MD5/SHA256) tanto de la copia como del original, para garantizar que no hubo alteraciones.
5. **Segmentación de material**: extraer únicamente los tramos correspondientes a las fechas y horas solicitadas, manteniendo el archivo original íntegro.
6. **Incorporación del video de smartphone**: descargarlo directamente al repositorio forense, registrar metadatos (fecha, hora, modelo del teléfono) y calcular hash.
7. **Documentación completa**: registrar en un informe todos los pasos realizados, quién los ejecutó, en qué momento y con qué herramientas, para asegurar trazabilidad.
8. **Almacenamiento seguro**: conservar la evidencia original y la copia en medios separados y en ubicaciones seguras, con acceso restringido.

Traslado a controles de seguridad de la información

En un tablero de control, estas acciones se reflejarán en indicadores como:

- **Integridad**: uso de hash para verificar que no hay cambios en los archivos.
- **Confidencialidad**: almacenamiento en ubicación segura y acceso restringido.
- **Disponibilidad**: existencia de copia forense para consulta sin comprometer el original.
- **Trazabilidad**: cadena de custodia documentada y firmada.

Conclusión

La validez de una evidencia audiovisual no depende únicamente de su contenido, sino de la forma en que fue obtenida y preservada. En este caso, la correcta aplicación de procedimientos forenses y la documentación exhaustiva aseguran que las grabaciones puedan ser presentadas en sede judicial sin riesgo de ser impugnadas por manipulación o alteración.

Caso 3 – Homicidio / Búsqueda de evidencia

Contexto y diagnóstico

En calidad de perito de control, se me solicita supervisar el manejo de evidencias digitales en un caso judicial por homicidio culposo, en el que la hipótesis apunta a una premeditación comprobable mediante redes sociales y mensajería. Las evidencias físicas y digitales disponibles incluyen:

- **Smartphone del presunto autor**
- **Smartphone de la víctima**
- **Gabinete (PC) del presunto autor**

El material ya ha sido adquirido y preservado, pero es mi responsabilidad verificar que se haya respetado la cadena de custodia y evaluar el riesgo de manipulación o contaminación de la evidencia.

Abordaje y acciones iniciales

La primera instancia con el cliente se centra en escuchar la descripción de las circunstancias y la metodología de recolección utilizada, transmitiendo seguridad en que el análisis se hará con criterios técnicos y judicialmente aceptables. Se acuerdan alcance, tiempos y costos del trabajo, y se solicita acceso a las actas y registros completos de la recolección original para evaluar trazabilidad.

Aplicación de la tabla de riesgo a la cadena de custodia

Sí, se puede aplicar una tabla de riesgo para valorar la cadena de custodia. Este instrumento pondera la probabilidad de que un error, manipulación o incumplimiento de procedimiento afecte la validez de la evidencia y el impacto que tendría:

- **Probabilidad alta**: manipulación por personal no autorizado, almacenamiento sin control de acceso, transporte sin sellado inviolable.
- **Impacto alto**: alteración de metadatos, pérdida de integridad de la copia forense, imposibilidad de reproducir la obtención.

  Cada elemento (smartphones y gabinete) debe evaluarse individualmente en cuanto a su estado, embalaje, documentación asociada, y registro de transferencias de custodia.

Recomendaciones para el cuidado en la obtención de datos

Para cada tipo de dispositivo:

- **Smartphones**: mantener en bolsas Faraday o modo avión para evitar alteraciones remotas, extracción de datos con herramientas certificadas (UFED, XRY), preservando particiones completas y generando hash de las imágenes.
- **Gabinete de PC**: desconectar de la red, realizar imagen forense de discos con bloqueadores de escritura, conservar todos los soportes físicos originales.
- **En todos los casos**: no realizar búsquedas o visualización directa en los dispositivos originales; cualquier análisis debe hacerse sobre copias verificadas.

Documentación de respaldo para las recomendaciones

Las recomendaciones se fundamentan en:

- **Principios de la IOCE (International Organization on Computer Evidence)**: no alterar la evidencia, acceso restringido, documentación y trazabilidad de toda acción.
- **ISO/IEC 27037**: directrices para identificación, recolección, adquisición y preservación de evidencia digital.
- **Buenas prácticas forenses reconocidas judicialmente**: uso de hash para verificación de integridad, actas firmadas en cada transferencia, almacenamiento seguro y controlado.

Conclusión

La cadena de custodia no es un simple formulario, sino un sistema de control continuo que, junto con la evaluación de riesgos, asegura que la evidencia digital mantenga su validez probatoria. La correcta aplicación de estándares internacionales y procedimientos forenses garantiza que el material pueda ser presentado en juicio sin riesgo de impugnación.

Caso 4 – Sistema web de ventas y subastas SaaS

Contexto y diagnóstico

La plataforma en cuestión funciona como un sistema de publicación y subasta online para profesionales matriculados en un colegio. No está respaldada por una empresa formal de software.

Algunos usuarios reportan presunto fraude en transacciones de alto valor, lo que genera desconfianza y cuestiona la integridad del sistema. La plataforma es SaaS (Software as a Service), lo que implica que el servicio, la infraestructura y el almacenamiento de datos dependen enteramente del proveedor.

Abordaje inicial

En la reunión con los representantes del colegio profesional, se escucha la descripción de las denuncias y se recopila información sobre el funcionamiento actual del sistema, políticas de seguridad, procesos de validación de usuarios y términos de uso. Se explica la necesidad de realizar una evaluación técnica y normativa, y se acuerda un plan de trabajo con alcances, tiempos y costos.

Identificación de seguridad y normas aplicables

Para un servicio SaaS de compraventa y subastas, las revisiones clave incluyen:

1. **Seguridad de la información (ISO/IEC 27001)**: implementación de políticas, controles técnicos y procedimientos que garanticen confidencialidad, integridad y disponibilidad de datos.
2. **Protección de datos personales (Ley 25.326 y GDPR si aplica)**: tratamiento seguro de datos personales de usuarios, consentimiento informado y derecho de rectificación/eliminación.
3. **Seguridad en desarrollo de software (OWASP Top 10)**: pruebas de vulnerabilidades comunes (inyección SQL, XSS, control de acceso roto, exposición de datos sensibles).
4. **Regulación de comercio electrónico**: cumplimiento de leyes locales que protegen a consumidores, incluyendo información clara sobre términos, condiciones y políticas de devolución.
5. **Pruebas de integridad transaccional**: asegurar que el sistema de subastas no pueda ser manipulado mediante scripts o modificaciones en el lado del cliente.
6. **Trazabilidad de operaciones**: logs de auditoría para registrar y poder reconstruir cualquier evento sospechoso.

Garantías para los usuarios

- **Autenticación y verificación de identidad**: validar que cada cuenta pertenezca efectivamente a un profesional matriculado, evitando cuentas falsas.
- **Cifrado de comunicaciones (TLS 1.2 o superior)** y cifrado de datos sensibles en reposo.
- **Política clara de resolución de disputas**: canal para reclamos y revisión de transacciones, con soporte documentado.

Controles en un tablero de seguridad

Indicadores sugeridos:

- **Confidencialidad**: encriptación aplicada, controles de acceso, MFA implementado.
- **Integridad**: validaciones de datos en servidor, logs inalterables.
- **Disponibilidad**: uptime documentado, plan de contingencia ante caídas.
- **Cumplimiento**: adherencia a normas ISO, leyes de protección de datos y regulaciones de comercio electrónico.
- **Trazabilidad**: existencia de registros de auditoría consultables para investigaciones internas.

Conclusión

Una plataforma de subastas SaaS que maneja operaciones de alto valor debe contar con un marco sólido de ciberseguridad y cumplimiento normativo. La ausencia de respaldo empresarial y la gestión por un único desarrollador incrementan el riesgo operativo. Un análisis técnico profundo, junto con la implementación de controles formales, es esencial para restaurar la confianza de los usuarios y asegurar la continuidad del servicio sin vulnerar derechos ni regulaciones.